

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (Grype 0.114.0 + OWASP DC) · Generated 2026-06-18 · Source: `pom.xml` (branch `fix/depscan-20260618-065936`)

Summary

Metric	Before remediation	After remediation
Total CVEs found	12	1
HIGH dependencies	5	1
MEDIUM dependencies	2	0
LOW dependencies	5	0
Supply-chain alerts	2	1 (untrusted HTTP repo — manual)
Typosquatted deps	1	0 (removed)

Post-remediation: remaining CVEs

Dependency	Version	Issue	CVSS	Severity	Action
mysql:mysql-connector-java	8.0.30	GHSA-m6vm-37g8-gqvh	8.9	HIGH	MAJOR_REVIEW — migrate to <code>com.mysql:mysql-connector-j:9.x</code>

CVEs cleared by this remediation

CVE / GHSA	Dependency	CVSS	Severity	Fix applied
CVE-2021-44228 (Log4Shell)	log4j-core / log4j-api	10.0	HIGH	2.14.1 → 2.25.4
CVE-2021-45046	log4j-core	9.0	HIGH	2.14.1 → 2.25.4
CVE-2021-45105	log4j-core	5.9	MEDIUM	2.14.1 → 2.25.4
GHSA-3pxv-7cmr-fjr4	log4j-core	—	MEDIUM	2.14.1 → 2.25.4
GHSA-vc5p-v9hr-52mj	log4j-core	—	MEDIUM	2.14.1 → 2.25.4
GHSA-6hg6-v5c8-fphq	log4j-core	—	MEDIUM	2.14.1 → 2.25.4
CVE-2020-8840 (+ 52 others)	jackson-databind	9.8	HIGH	2.9.8 → 2.18.3
CVE-2023-22102	mysql-connector-java	8.9	HIGH	MAJOR_REVIEW pending
CVE-2024-47554	commons-io	8.7	HIGH	2.4 → 2.18.0
CVE-2025-48924 + GHSA-j288	commons-lang3	6.5	MEDIUM	3.4 → 3.18.0
CVE-2023-2976 + CVE-2020-8908	guava	5.5	MEDIUM	24.1.1-jre → 33.4.0-jre

Supply-chain alerts

RESOLVED — Typosquatted dependency removed. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonated `com.fasterxml.jackson.core` ; the coordinate did not exist on Maven Central. Removed by this remediation.

OPEN — Untrusted repository. `http://insecure-mirror.example.net/maven2` is a plain-HTTP Maven repository (MITM artifact-injection risk). Requires manual removal from `<repositories>` .

Machine-readable source: `depscan-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 1 / Stage 3 (post-remediation).